HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN

BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: THỰC TẬP CƠ SỞ
MÃ HỌC PHẦN: INT13147

BÀI THỰC HÀNH 3.2
TẤN CÔNG VÀO MẬT KHẨU

Sinh viên thực hiện:

B22DCAT303 - Nguyễn Khắc Trí

Giảng viên hướng dẫn: PGS. TS. Hoàng Xuân Dậu

HỌC KỲ 2 NĂM HỌC 2024-2025

MỤC LỤC

DANH MỤC CÁC HÌNH VẼ 3
DANH MỤC CÁC TỪ VIẾT TẮT 4
CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH 5
1.1 Mục đích 5
1.2 Tìm hiểu lý thuyết 5
1.2.1 Các công cụ Crack mật khẩu 5
CHƯƠNG 2. NỘI DUNG THỰC HÀNH 10
2.1 Chuẩn bị môi trường 10
2.2 Các bước thực hiện 10
2.2.1 Crack mật khẩu trên Windows 10
2.2.2 Crack mật khẩu trên Linux 14
TÀI LIỆU THAM KHẢO 17

DANH MỤC CÁC HÌNH VẼ

Hình 1– Tạo 3 người dùng mới 10
Hình 2 – Các gói cần cài đặt 10
Hình 3 – Giải nén Các gói cần cài đặt 11
Hình 4 – Giao diện OphCrack sau khi tải 11
Hình 5 – Trích xuất các mật khẩu đăng nhập 11
Hình 6 – Kiểm tra lại file B22DCAT303-NKT.txt 12
Hình 7 – Kích hoạt Rainbow 12
Hình 8 – Chọn file pwdump 13
Hình 9 – Kết quả sau khi crack mật khẩu 13
Hình 10 – Tạo các user và đặt mật khẩu 14
Hình 11 – Kiểm tra lại trên file /etc/password 15
Hình 12 – Kết hợp 2 file /etc/passwd và file /etc/shadow 15
Hình 13 – Crack thành công mật khẩu 4 kí tự, 6 kí tự 15
Hình 14 – Crack thành công mật khẩu 8 kí tự 16

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
SAM	Security Account Manager	Quản lý tài khoản bảo mật
NTLM	NT LAN Manager	Quản lý mạng LAN của Microsoft
JTR	John the Ripper	Công cụ crack mật khẩu
GPU	Graphics Processing Unit	Đơn vị xử lý đồ họa

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

1.1 Mục đích

- Hiểu được mối đe dọa về tấn công mật khẩu.
- Hiểu được nguyên tắc hoạt động của một số công cụ Crack mật khẩu trên các hệ điều hành Linux và Windows.
- Biết cách sử dụng công cụ để Crack mật khẩu trên các hệ điều hành Linux và Windows.

1.2 Tìm hiểu lý thuyết

1.2.1 Các công cụ Crack mật khẩu

1.2.1.1 Ophcrack

Ophcrack là một công cụ miễn phí và mã nguồn mở được thiết kế để crack mật khẩu của hệ điều hành Windows. Nó chủ yếu sử dụng Rainbow Tables (bảng màu) để phục hồi mật khẩu từ các giá trị hash được lưu trữ trong tệp SAM (Security Account Manager) của Windows.

Tính năng của Ophcrack:

- Rainbow Tables: Ophcrack sử dụng bảng màu để nhanh chóng so khớp các giá trị hash với các mật khẩu tương ứng. Rainbow Tables là những bảng tra cứu chứa các giá trị hash của các mật khẩu phổ biến và các kết hợp của chúng. Điều này giúp giảm thời gian tính toán so với brute-force, đặc biệt khi mật khẩu không quá phức tạp.
- Chạy trực tiếp từ USB: Ophcrack có thể chạy từ một USB mà không cần phải cài đặt, rất hữu ích khi bạn muốn crack mật khẩu mà không thay đổi bất kỳ thông tin nào trên máy tính mục tiêu.
- Giao diện đồ họa: Ophcrack cung cấp một giao diện người dùng đồ họa đơn giản, giúp dễ dàng sử dụng cho cả người mới bắt đầu và các chuyên gia.
- Hỗ trợ nhiều phiên bản Windows: Ophcrack có thể crack mật khẩu trên nhiều phiên bản Windows, bao gồm Windows XP, Vista, 7, và 8 (cả phiên bản 32-bit và 64-bit).

Cách thức hoạt động của Ophcrack:

- Truy xuất file SAM: Ophcrack yêu cầu truy xuất tệp SAM từ hệ thống Windows để có thể lấy các giá trị hash của mật khẩu. Tệp này thường được lưu trữ trong thư mục **C:\Windows\System32\config** trên máy tính Windows.
- Sử dụng Rainbow Tables: Sau khi lấy được các giá trị hash từ tệp SAM, Ophcrack sẽ so sánh các hash này với các giá trị trong bảng màu để tìm ra mật khẩu tương ứng. Nếu hash có trong bảng, Ophcrack sẽ phục hồi mật khẩu nhanh chóng.
- Brute-force (nếu cần thiết): Nếu phương pháp rainbow table không thành công, Ophcrack có thể sử dụng brute-force, thử tất cả các kết hợp ký tự, mặc dù phương pháp này chậm hơn và không hiệu quả đối với mật khẩu dài và phức tạp.

1.2.1.2 John the Ripper (JTR)

John the Ripper (JTR) là một công cụ mã nguồn mở phổ biến, được sử dụng để crack mật khẩu trên nhiều hệ thống khác nhau bằng cách sử dụng các kỹ thuật như brute-force, dictionary attack, và các phương pháp tối ưu hóa khác. Công cụ này hỗ trợ một loạt các thuật toán mã hóa mật khẩu khác nhau, bao gồm MD5, SHA-1, NTLM, DES, bcrypt và nhiều hệ thống khác, giúp phục hồi mật khẩu từ các hash mã hóa đã lưu trữ.

Các tính năng chính của John the Ripper:

- Hỗ trợ nhiều loại mã hóa mật khẩu: John the Ripper có thể crack các hash mật khẩu được lưu trữ trong nhiều định dạng mã hóa khác nhau, bao gồm:
  - MD5, SHA-1, SHA-256, SHA-512
  - Windows LM và NTLM (thường được dùng trong các hệ điều hành Windows)
  - Unix DES và Blowfish
  - bcrypt, scrypt
  - Các hash từ các hệ thống khác như OpenSSL, Kerberos, và nhiều hệ thống mã hóa khác.
- Các phương pháp tấn công:
  - Brute-force Attack: Đây là phương pháp thử tất cả các kết hợp có thể của ký tự cho đến khi tìm được mật khẩu đúng. Mặc dù phương pháp này rất hiệu quả, nhưng nó có thể rất chậm, đặc biệt đối với các mật khẩu dài và phức tạp.
  - Dictionary Attack: Phương pháp này sử dụng một từ điển mật khẩu (có thể là các mật khẩu phổ biến hoặc các từ đã biết) để thử nghiệm. Đây là phương pháp nhanh hơn brute-force, nhưng phụ thuộc vào việc mật khẩu có nằm trong từ điển hay không.
  - Hybrid Attack: Là sự kết hợp giữa dictionary attack và brute-force, trong đó các từ điển được kết hợp với các biến thể như thêm số vào cuối từ, viết hoa chữ cái đầu, hay thay đổi ký tự đặc biệt.
- Tối ưu hóa hiệu suất:
  - GPU Acceleration: John the Ripper hỗ trợ sử dụng GPU (card đồ họa) để tăng tốc quá trình cracking, giúp giảm thời gian thử mật khẩu, đặc biệt là với các mật khẩu dài hoặc hệ thống bảo mật mạnh.
  - Rainbow Tables: Mặc dù John the Ripper không phải là công cụ chính để sử dụng rainbow tables, nhưng nó có thể kết hợp với các bảng này để tối ưu hóa quá trình bẻ khóa các hash mật khẩu.
  - Optimized Algorithms: Các thuật toán mã hóa phổ biến như DES hay bcrypt có thể được tối ưu hóa trong John the Ripper để chạy nhanh hơn, đặc biệt khi sử dụng phần cứng mạnh mẽ.
- Khả năng mở rộng và tùy chỉnh:

- Tạo từ điển tùy chỉnh: Người dùng có thể tạo các từ điển riêng, bổ sung các từ khóa hoặc các mật khẩu thường gặp từ các nguồn khác nhau.
- Quy tắc và Biến thể: John the Ripper cho phép người dùng áp dụng các quy tắc để biến đổi mật khẩu trong từ điển, ví dụ: chuyển các chữ cái thành chữ hoa, thay đổi thứ tự ký tự, thêm số vào cuối từ, v.v.
- Hỗ trợ nhiều nền tảng: John the Ripper có thể chạy trên nhiều hệ điều hành như Linux, macOS, Windows, và các hệ thống Unix-like khác, cho phép người dùng chạy công cụ này trên các máy tính với cấu hình khác nhau.

Cách thức hoạt động:

- Truy xuất hash mật khẩu: Để sử dụng John the Ripper, bạn cần truy xuất các hash mật khẩu từ hệ thống mục tiêu. Ví dụ, trên Linux, các hash mật khẩu thường được lưu trữ trong tệp **/etc/shadow**, trong khi trên Windows, mật khẩu có thể được lưu trong tệp SAM (Security Account Manager).
- Chọn phương pháp tấn công: John the Ripper cho phép bạn lựa chọn nhiều phương pháp tấn công để thử mật khẩu:
  - Brute-force: Thử tất cả các khả năng để tìm ra mật khẩu.
  - Dictionary: Sử dụng từ điển đã có sẵn để thử mật khẩu.
  - Hybrid: Kết hợp từ điển và brute-force, thử các biến thể mật khẩu.
- Tăng tốc với GPU: Để tăng tốc quá trình, JTR có thể sử dụng GPU, giúp giảm thời gian tấn công khi xử lý các mật khẩu phức tạp hoặc hệ thống mã hóa mạnh.
- Quản lý và theo dõi tiến trình: Công cụ cung cấp các tính năng giám sát tiến trình cracking, giúp người dùng theo dõi quá trình và đánh giá hiệu quả của các phương pháp đang được sử dụng.

1.2.1.3 Hashcat

Hashcat là phần mềm crack hash/khôi phục mật khẩu từ hash nhanh nhất và tiên tiến nhất hiện nay trên giao diện dòng lệnh. Hashcat cung cấp cho người sử dụng 5 chế độ tấn công/khôi phục mật khẩu khác nhau áp dụng cho hơn 300 thuật toán hash khác nhau. Hashcat là một phần mềm mã nguồn mở và hoàn toàn miễn phí. Hashcat có thể được sử dụng trên nhiều nền tảng khác nhau như Linux, Windows và MacOS.

Ở thời điển hiện tại, Hashcat có thể sử dụng GPU, CPU và các phần cứng tăng tốc độ tính toán khác trên hệ thống máy tính để tăng tốc độ phá password hash. Tuy nhiên, vì phần lớn chúng ta sử dụng máy ảo Kali Linux trên Virtual Box, nên chúng ta sẽ mất đi sự hỗ trợ đắc lực của GPU (card đồ họa).

Trước khi sử dụng Hashcat, chúng ta phải xác định thuật toán mã hóa, có thể sử dụng công cụ: Hash Identifier (ở ngay trên Kali), Hash Analyzer của TunnelsUP.com (online), Password hash identification (online)

Hash cat hỗ trợ 4 hình thức crack hash:

- Dictionary (-a 0): Bạn sẽ cung cấp cho Hashcat một danh sách (có thể là tập hợp những passwords hay được dùng nhất). Hashcat sẽ sử dụng lần lượt từng giá trị trong danh sách này để hash nó với thuật toán đã chỉ định và so sánh với hash đầu vào, nếu kết quả sai, Hashcat sẽ thử giá trị tiếp theo trong danh sách được cung cấp, nếu đúng thì Hashcat trả lại kết quả đã tạo nên giá trị hash trùng khớp với giá trị hash đầu vào.
- Combination (-a 1): Tương tự như Dictionary attack ở trên, tuy nhiên khi dùng Combination các bạn sẽ phải cung cấp 2 danh sách chứ không phải chỉ 1 danh sách như Dictionary attack. Hình thức tấn công này được sử dụng khi bạn muốn tìm username và password của người dùng. Lúc này bạn sẽ cần 1 danh sách những usernames hay được dùng nhất và 1 danh sách những passwords hay được dùng nhất. Hashcat sẽ lần lượt tạo ra các cặp kết hợp giữa danh sách username và danh sách password và lần lượt thử đăng nhập bằng các cặp kết hợp này cho đến khi tìm ra được username và password chính xác hoặc cho đến khi tất cả các cặp kết hợp đều đã được thử và không có cặp nào chính xác.
- Mask (-a 3): Mask attack tương tự như Bruteforce attack, bạn sẽ cung cấp một loạt các ký tự ví dụ a, b, c, d, e, f, 1, 2, 3, v.v. và từ các ký tự được cung cấp này, Hashcat sẽ tự kết hợp các ký tự lại với nhau và tạo ra các chuỗi ký tự ngẫu nhiên ví dụ như abc123, và các chuỗi này sẽ được dùng để tấn công giống như Dictionary attack. Cách tấn công này sẽ phù hợp để tìm những username và password không nằm trong danh sách được cung cấp khi tấn công Dictionary attack, tuy nhiên sẽ rất mất thời gian.
- Hybrid (-a 6 và -a 7): Kết hợp cả Dictionary attack và Mask attack.

Cú pháp cơ bản:

hashcat -a <tấn-công> -m <thuật-toán-hash> <file-chứa-hash-đầu-vào> <danh sách hoặc chuỗi-ký-tự>

Theo đó ta có các thành phần bắt buộc phải có như sau:

- a: Số của hình thức tấn công:
  - -a 0: Dictionary
  - -a 1: Combination
  - -a 3: Mask
  - -a 6 và -a 7: Dictionary + Mask
- -m: Số của thuật toán hash (bất cứ khi nào quên, bạn đều có thể tra cứu lại bằng lệnh hashcat –help). Trong ví dụ mình dùng -m 0 để chỉ thuật toán hash MD5.
- File chứa hash đầu vào
- File chứa danh sách nếu tấn công Dictionary hoặc chuỗi ký tự nếu tấn công Mask

VD: hashcat -a 0 -m 0 file-chứa-hash file-danh-sách

Chú ý: trên Kali cũng có 1 danh sách mật khẩu: /usr/share/wordlists/rockyou.txt

1.2.1.4 PWDUMP

PWDUMP là một công cụ được sử dụng để trích xuất mật khẩu hash từ hệ điều hành Windows. Công cụ này hoạt động bằng cách lấy thông tin từ tệp SAM (Security Account Manager) và SYSTEM để thu thập các mật khẩu hash của các tài khoản người dùng. Các hash này sau đó có thể được sử dụng trong các công cụ khác như John the Ripper hoặc Hashcat để crack mật khẩu.

Cách thức hoạt động của PWDUMP:

- Trích xuất hash mật khẩu: PWDUMP truy xuất thông tin mật khẩu từ tệp SAM (nơi Windows lưu trữ thông tin đăng nhập người dùng) và tệp SYSTEM (cung cấp thông tin về cấu hình hệ thống). Các hash mật khẩu này được mã hóa bằng thuật toán LM hoặc NTLM.
- Tạo tệp đầu ra: Sau khi trích xuất các hash, PWDUMP sẽ tạo ra một tệp đầu ra chứa thông tin về các tài khoản người dùng, cùng với các hash mật khẩu của họ.
- Dùng để crack mật khẩu: Các hash này có thể được sử dụng trong các công cụ như John the Ripper hoặc Hashcat để thử bẻ khóa mật khẩu bằng các phương pháp tấn công như brute-force, dictionary attack, hoặc các kỹ thuật tối ưu khác.

Ví dụ về cú pháp sử dụng PWDUMP:

```
pwdump7 SYSTEM SAM > hashes.txt
```

- **SYSTEM**: Tệp chứa thông tin về cấu hình hệ thống.
- **SAM**: Tệp chứa các hash mật khẩu người dùng.
- **> hashes.txt**: Chuyển kết quả đầu ra vào tệp hashes.txt

CHƯƠNG 2. NỘI DUNG THỰC HÀNH

2.1 Chuẩn bị môi trường

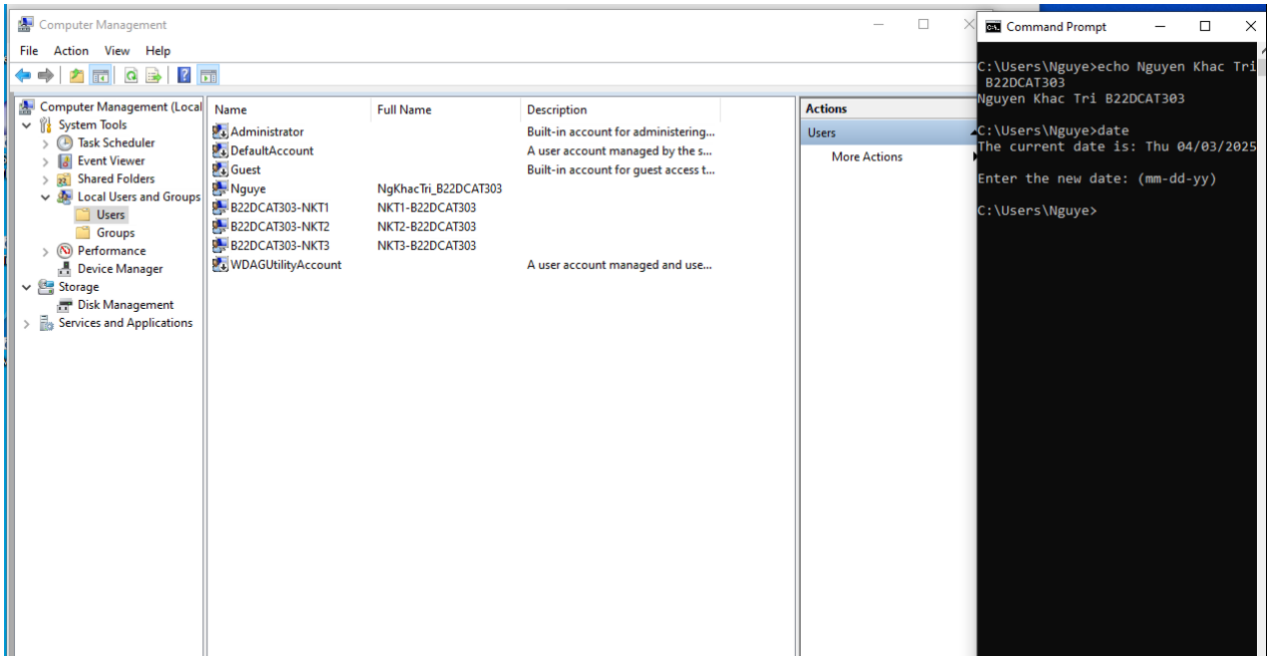
- Cài đặt công cụ ảo hóa.
- Phần mềm hệ điều hành Linux và Windows.
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Linux
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Windows

2.2 Các bước thực hiện

2.2.1 Crack mật khẩu trên Windows

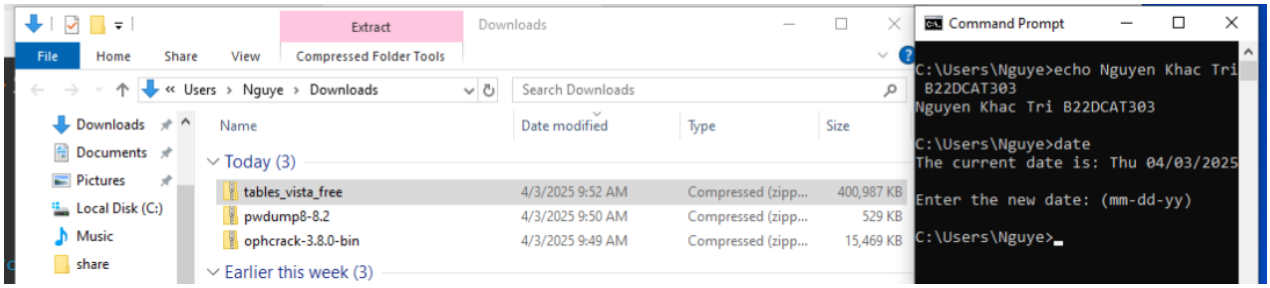
Thử nghiệm crack mật khẩu trên hệ điều hành Windows với ít nhất 3 trường hợp mật khẩu có chiều dài là 4 ký tự, 6 ký tự và 8 ký tự,.... Các tên tài khoản này đều có phần đầu là mã sinh viên.

Tạo thêm 3 tài khoản trên Windows có mật khẩu thỏa mã 4 kí tự, 6 kí tự, 8 kí tự: Computer Management -> Local Users and Group -> Chuột phải vào Users -> New User.

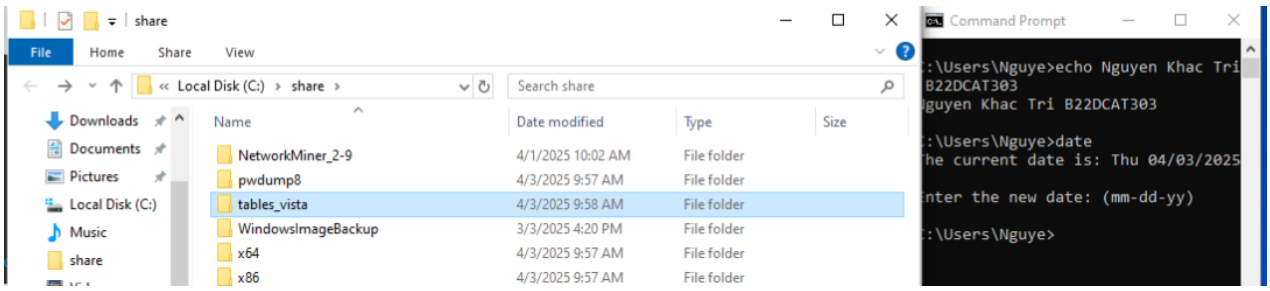


Hình 1– Tạo 3 người dùng mới

Tải công cụ PwDump8, Ophcrack (phải tải cả các Rainbow của Ophcrack). Giải nén các tập tin đã tải và tiến hành cài đặt.

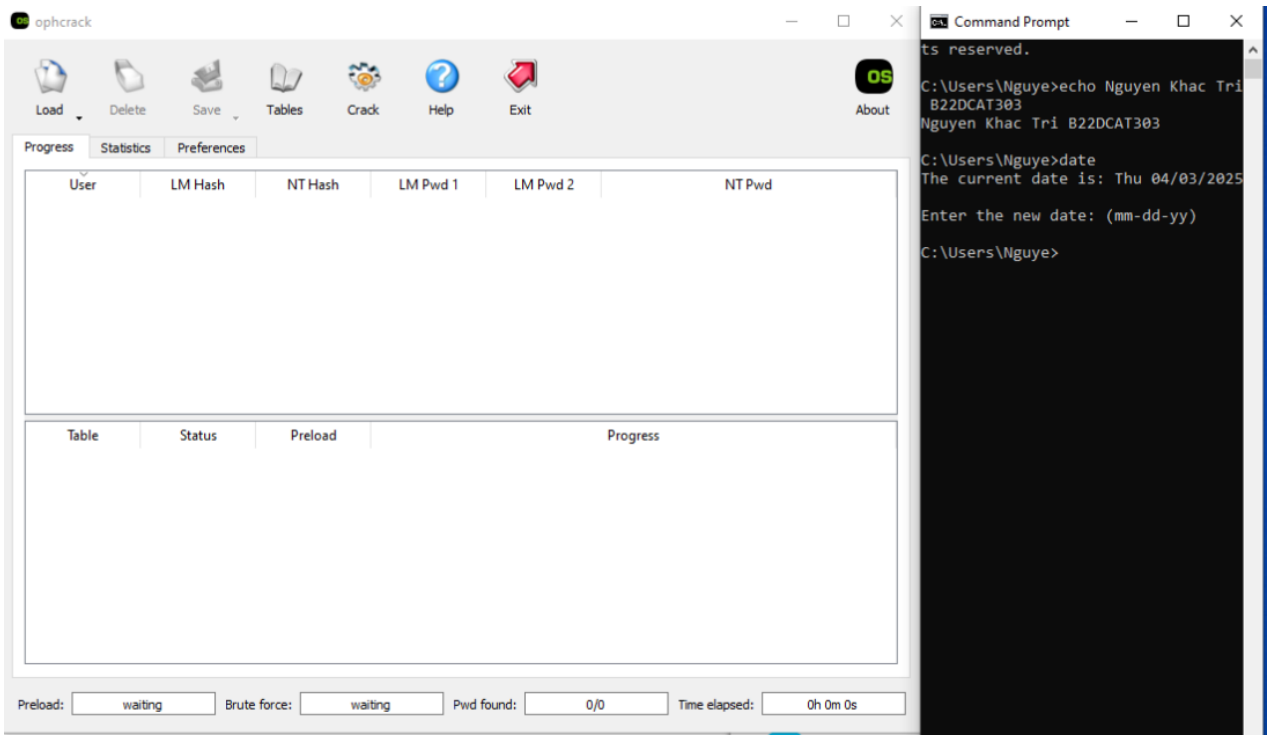


Hình 2 – Các gói cần cài đặt



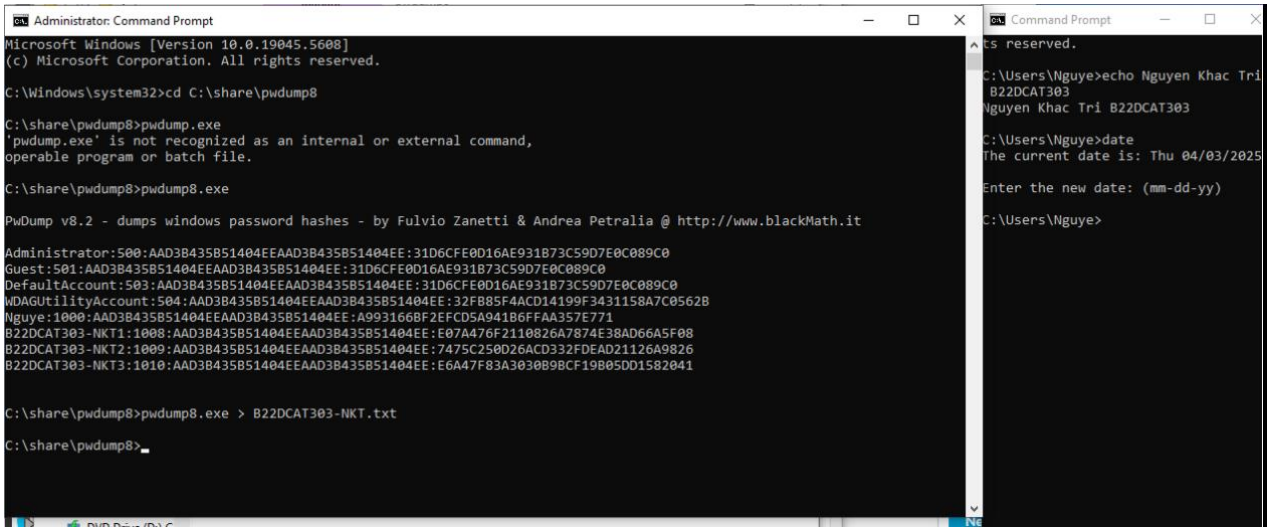
Hình 3 – Giải nén Các gói cần cài đặt

Khởi động OphCracrk



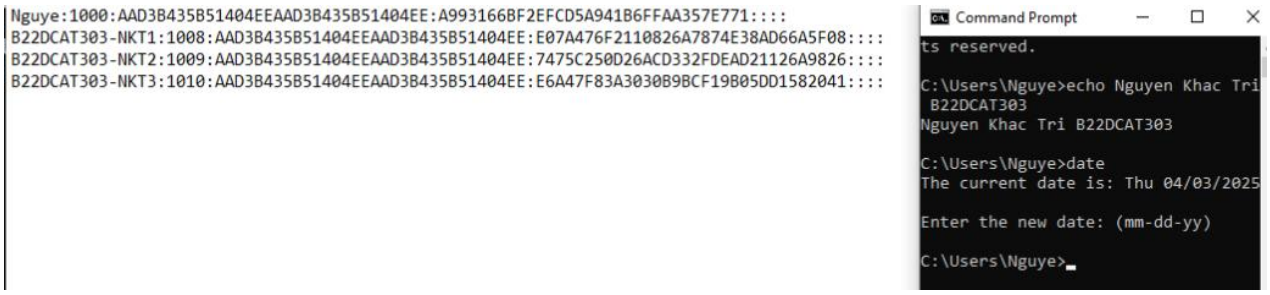
Hình 4 – Giao diện OphCrack sau khi tải

Chạy PwDump với quyền Administrator để trích xuất mật khẩu đăng nhập, đưa vào file B22DCAT303-NKT.txt.



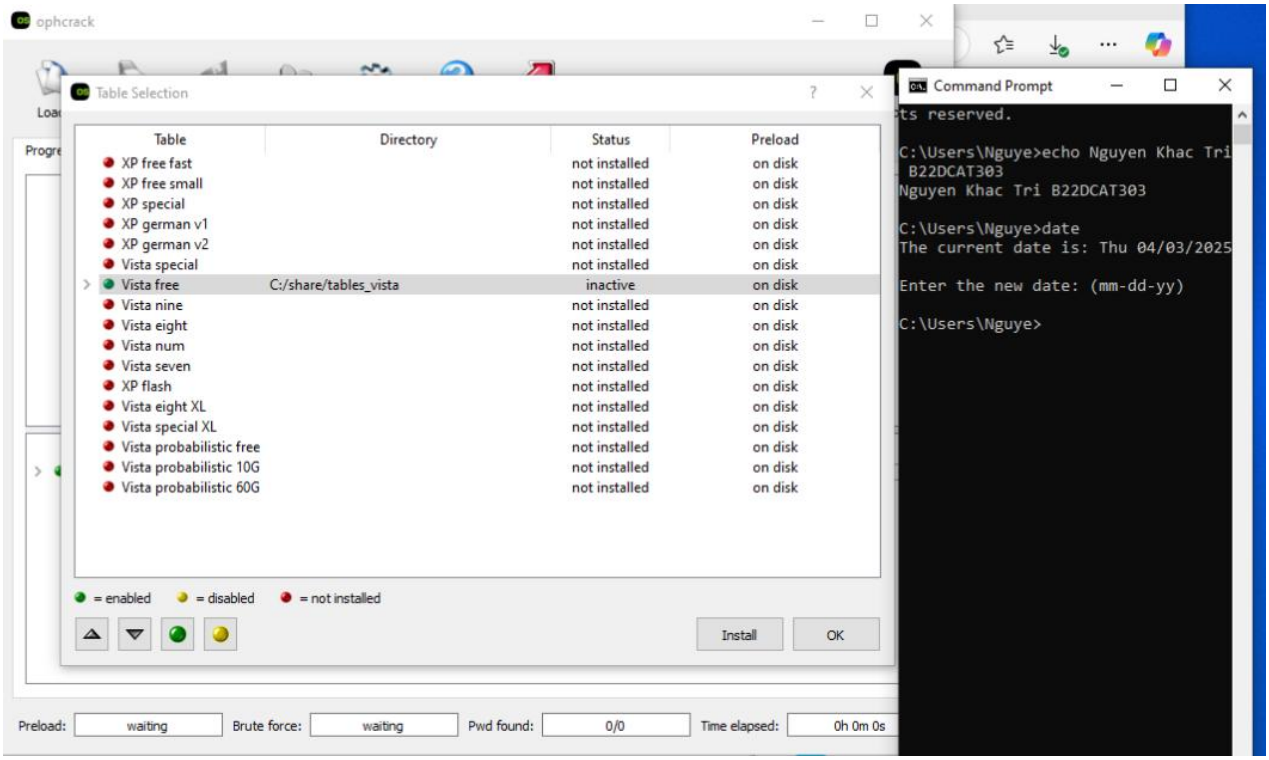
Hình 5 – Trích xuất các mật khẩu đăng nhập

Lưu ý, mỗi dòng trong file B22DCAT303-NKT.txt cần phải đảm bảo đúng định dạng như sau:



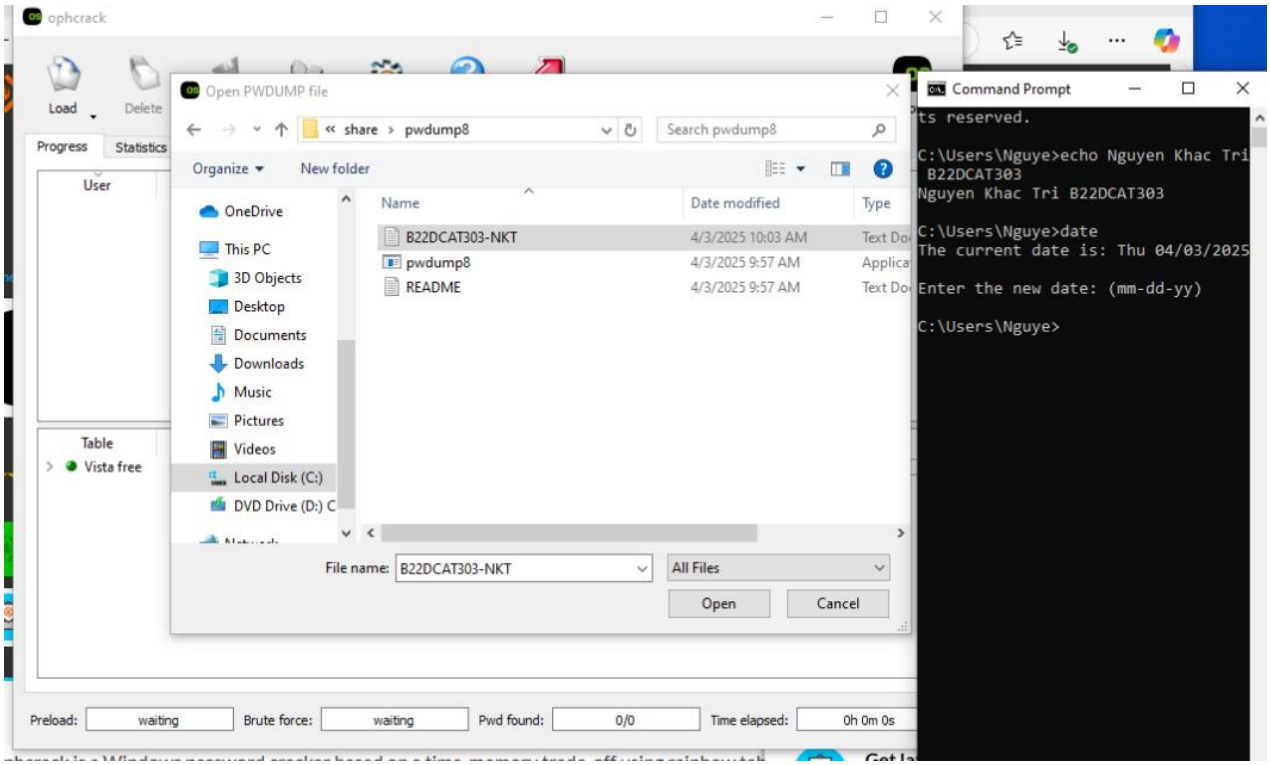
Hình 6 – Kiểm tra lại file B22DCAT303-NKT.txt

Sử dụng Ophcrack để crack mật khẩu: Đầu tiên phải kích hoạt các Rainbow đã tải: Tables -> chọn thư mục đã lưu Rainbow.



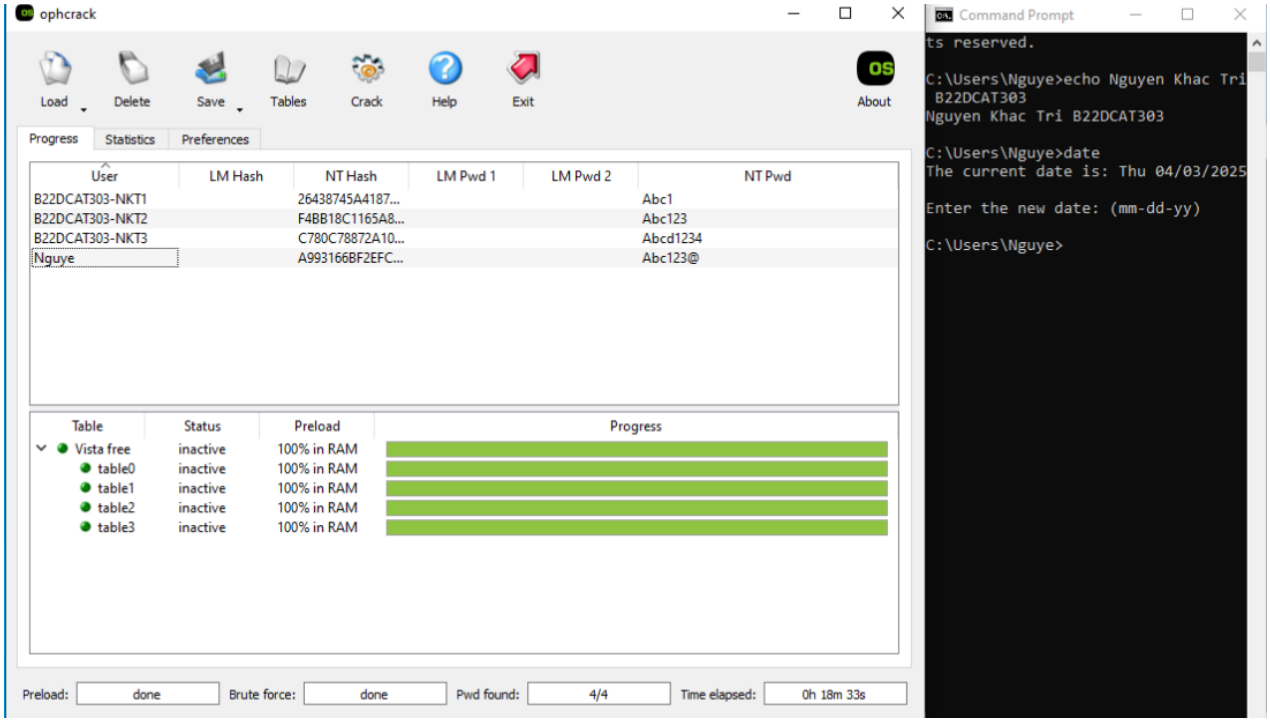
Hình 7 – Kích hoạt Rainbow

Crack các mật khẩu đã lưu trên file B22DCAT303-NKT.txt: Load → PWDUMP File → chọn File đã lưu. Đợi file tải hết.



Hình 8 – Chọn file pwdump

Chọn Crack để tiến hành bẻ khóa mật khẩu. Kết quả đã bẻ khóa thành công mật khẩu 4 kí tự, 6 kí tự, 8 kí tự.

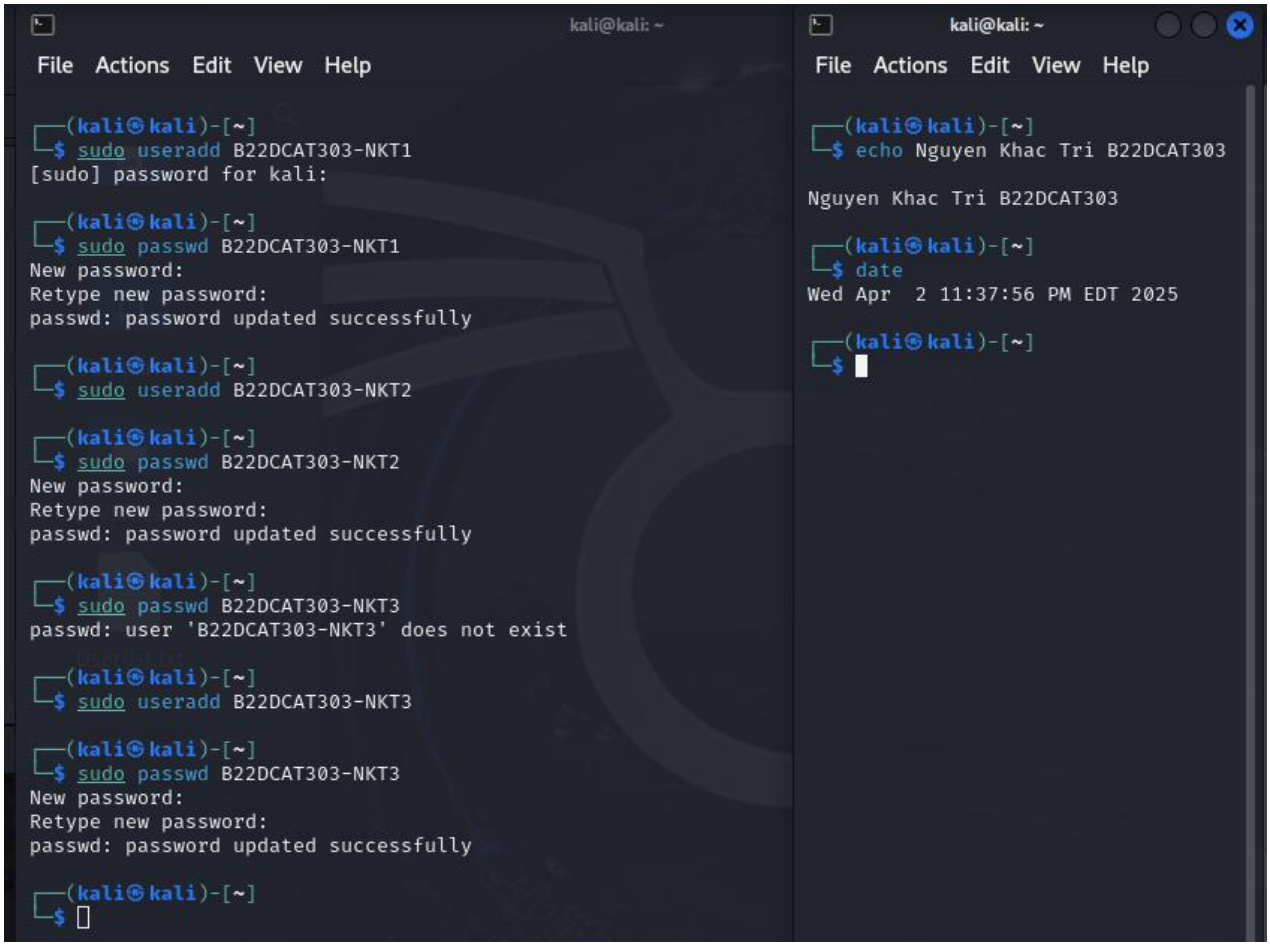


Hình 9 – Kết quả sau khi crack mật khẩu

2.2.2 Crack mật khẩu trên Linux

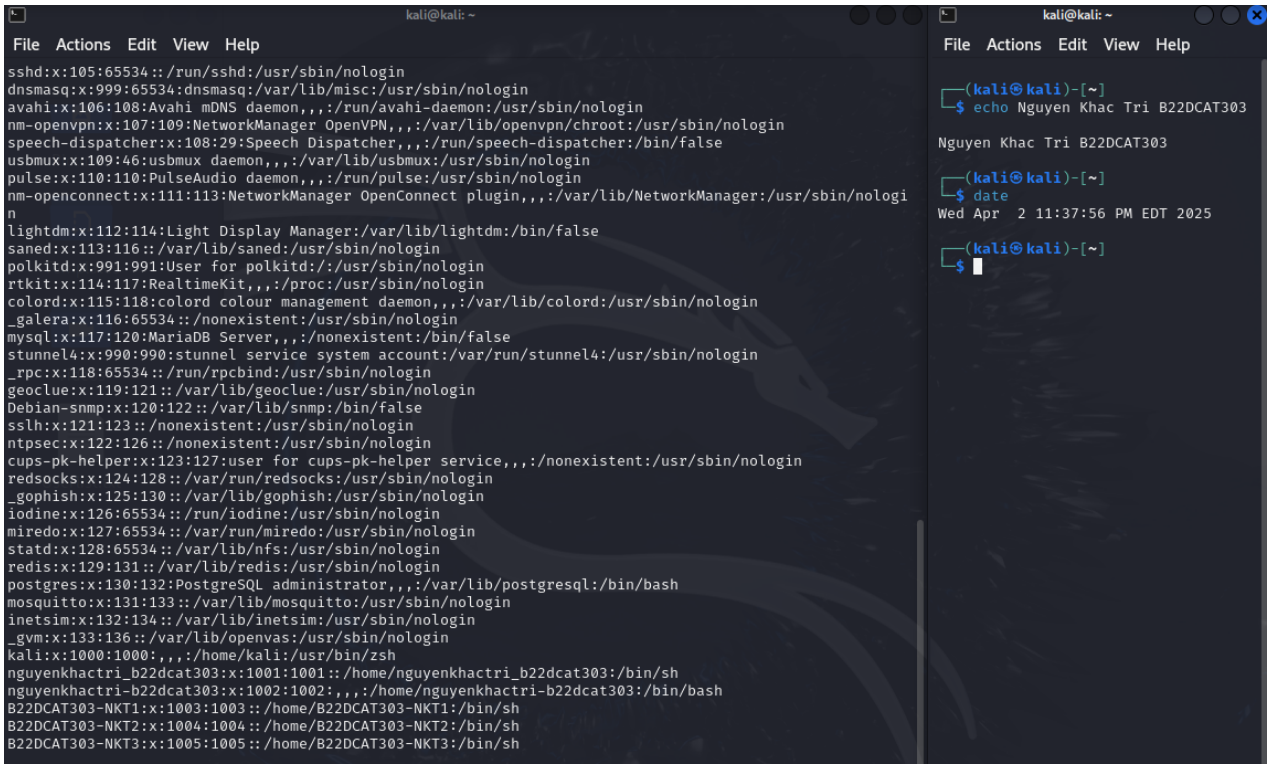
Thử nghiệm crack mật khẩu trên hệ điều hành Linux với ít nhất 3 trường hợp mật khẩu có chiều dài là 4 ký tự, 6 ký tự và 8 ký tự,.... Các tên tài khoản này đều có phần đầu là mã sinh viên.

Tạo user và đặt mật khẩu.



Hình 10 – Tạo các user và đặt mật khẩu

Kiểm tra lại trên file /etc/password

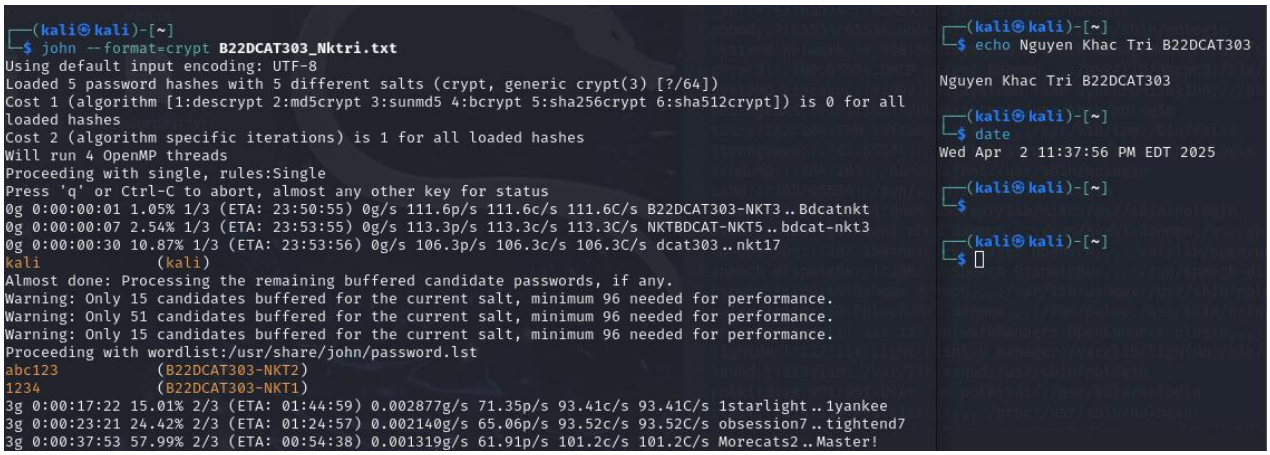


Hình 11 – Kiểm tra lại trên file /etc/password

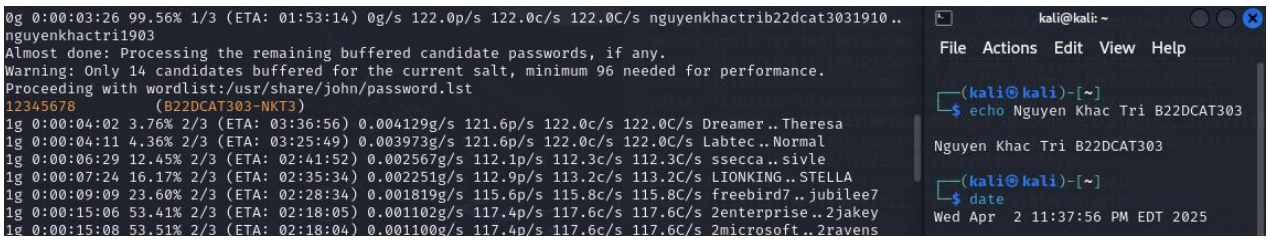
Kết hợp 2 file /etc/passwd và file /etc/shadow để phục vụ cho quá trình crack mật khẩu sử dụng John The Ripper (đây là công cụ có sẵn trên Kali).

Hình 12 – Kết hợp 2 file /etc/passwd và file /etc/shadow

Kết quả: crack thành công mật khẩu 4 kí tự, 6 kí tự, 8 kí tự



Hình 13 – Crack thành công mật khẩu 4 kí tự, 6 kí tự



Hình 14 – Crack thành công mật khẩu 8 kí tự

TÀI LIỆU THAM KHẢO

[1] Chương 2, Giáo trình Cơ sở an toàn thông tin, Học viện Công Nghệ Bưu Chính Viễn Thông, 2020 của tác giả Hoàng Xuân Dậu.

[2] Chapter 11 Authentication and Remote Access, sách Principles of Computer Security CompTIA Security+ and Beyond Lab Manual (Exam SY0-601) by Jonathan S. Weissman